

SC-100

Microsoft Cybersecurity Architect Security Architecture Cheat Sheet & Scenario Study Guide

Purpose: A compact "when to use what" guide for scenario-based SC-100 questions. Focus on architectural selection, service boundaries, common traps, and rapid revision.

Aligned to the English SC-100 skills measured as of July 28, 2026

Current domain weighting: 20-25% | 25-30% | 25-30% | 20-25%

Exam principle: identify the asset -> identify the threat/control objective -> choose the narrowest service that directly solves it.

0. How to Use This Guide

Use the first two pages for rapid decisions; use later chapters for deeper comparison and scenario practice.

SC-100 is an architect-level exam. Questions frequently ask you to design, evaluate, recommend, select, or prioritize controls rather than configure them step by step.

Four-question method: For every service, know: (1) what it protects, (2) what problem it solves, (3) when to choose it, and (4) which similar service is the wrong choice.

Current exam domains

Domain	Weight	Architect focus
Security best practices and priorities	20-25%	Ransomware resiliency, MCRA/MCSB, Zero Trust, CAF, Well-Architected, landing zones, DevSecOps, secure AI adoption
Security operations, identity, compliance	25-30%	XDR/SIEM/SOAR, Entra identity, privileged access, Purview, Policy, compliance
Infrastructure security	25-30%	Defender for Cloud, Arc, EASM, Exposure Management, endpoints, IoT/OT, network security, SSE
Applications and data	20-25%	M365 security, Defender/Purview/Intune, application lifecycle, workload identity, API/WAF, encryption and data security

Master decision matrix - if the question says this, think this

Scenario keyword	Choose	Why
Endpoint attack / EDR / ransomware on device	Microsoft Defender for Endpoint	Threat detection and response on endpoints
Active Directory identity attack / lateral movement	Microsoft Defender for Identity	Hybrid identity threat detection
Phishing / malicious links / attachments	Microsoft Defender for Office 365	Email and collaboration threat protection
Shadow IT / SaaS visibility / CASB	Microsoft Defender for Cloud Apps	Discover and govern SaaS usage
Correlate Microsoft endpoint + identity + email incidents	Microsoft Defender XDR	Cross-domain XDR investigation
SIEM / third-party logs / enterprise SOC / SOAR	Microsoft Sentinel	Central analytics, hunting, automation
Azure/AWS/GCP posture and workload protection	Microsoft Defender for Cloud	CNAPP: CSPM + workload protection
Unknown Internet-facing assets	Defender EASM	Outside-in external attack surface discovery
Cross-workload attack paths to critical assets	Security Exposure Management	Exposure graph, attack paths, choke points
On-prem/AWS/GCP servers or Kubernetes managed in Azure	Azure Arc	Hybrid/multicloud resource control plane
Delegate Azure resource management across tenants / MSSP	Azure Lighthouse	Cross-tenant Azure resource delegation
Cloud excessive/unused permissions / CIEM	Defender for Cloud Permissions Management	Cloud entitlement analysis and least privilege
Temporary privileged role activation	Entra PIM	Just-in-time privileged access
Risk/condition based sign-in decision	Conditional Access	If conditions -> then access controls
Risky users/sign-ins	Entra ID Protection	Risk detection and remediation signals
Does access still need to exist?	Access Reviews	Periodic access recertification
Temporary bundle of project/partner resources	Entitlement Management	Access packages and lifecycle
AI agent requires governed identity	Microsoft Entra Agent ID	Identity lifecycle and policy for AI agents
Azure workload needs credentials-free resource access	Managed Identity	Workload identity without stored secrets
Who may perform an Azure action?	Azure RBAC	Authorization by role and scope
What resource configurations are allowed?	Azure Policy	Govern and enforce resource configuration
Security posture metric / improvement score	Microsoft Secure Score	Prioritize posture improvements
Device configuration and compliance	Microsoft Intune	MDM/MAM, security configuration and compliance
PLC / SCADA / OT / ICS	Defender for IoT	Agentless/specialized OT monitoring
Sensitive-data classification and labels	Microsoft Purview Information Protection	Discover/classify/protect information
Prevent sensitive-data leakage	Microsoft Purview DLP	Control exfiltration and inappropriate sharing
Insider data theft / risky employee behavior	Purview Insider Risk Management	Insider risk signals and cases

Scenario keyword	Choose	Why
Who performed a Microsoft 365 action?	Microsoft Purview Audit	Unified audit trail
Central VNet firewall / FQDN / IDPS	Azure Firewall	Managed network firewall
Subnet/NIC L3/L4 filtering	NSG	Distributed stateful packet filtering
SQL injection / XSS / HTTP attacks	Web Application Firewall	Layer 7 web protection
Volumetric L3/L4 DDoS	Azure DDoS Protection	Network-layer DDoS mitigation
RDP/SSH without VM public IP	Azure Bastion	Secure administrative connectivity
PaaS service gets private IP in VNet	Private Endpoint / Private Link	Private service connectivity
Secure Internet/SaaS browsing	Entra Internet Access	Identity-aware secure web gateway
ZTNA to private/internal apps	Entra Private Access	Per-app private access without broad VPN
Secrets / keys / certificates	Azure Key Vault	Secret and cryptographic material management
API authentication/throttling/governance	Azure API Management	API gateway and policy enforcement
Malicious activity in Blob/Storage	Defender for Storage	Storage workload threat protection
Database attacks/anomalies	Defender for Databases	Database workload threat protection
AKS/EKS/GKE/container runtime threats	Defender for Containers	Container/Kubernetes protection

1. Security Operations & Microsoft Defender Ecosystem

Know exactly which telemetry domain each Defender product owns, then decide when XDR or SIEM is needed above it.

Microsoft Defender for Endpoint (MDE)

What it is: Endpoint Detection and Response (EDR), attack surface reduction, next-generation protection, vulnerability management, and automated investigation for supported endpoints.

Use when: The threat is on laptops, desktops, mobile devices, or servers: ransomware, malicious process activity, endpoint compromise, attack-surface reduction, or endpoint vulnerabilities.

Key capabilities: EDR, Attack Surface Reduction (ASR), Defender Vulnerability Management, endpoint risk signals.

Exam cue: If the noun is "endpoint" and the verb is detect/investigate/respond, choose MDE.

Do not confuse: Intune manages/configures devices; MDE detects and responds to endpoint threats.

Microsoft Defender for Identity (MDI)

What it is: Identity threat detection focused on Active Directory and hybrid identity infrastructure.

Use when: You need to detect credential theft, reconnaissance, suspicious privilege escalation, pass-the-hash, lateral movement, or attacks involving domain controllers/AD identities.

Exam cue: AD/domain-controller attack -> Defender for Identity.

Do not confuse: Entra ID Protection detects risky users/sign-ins; Defender for Identity detects identity attacks and suspicious AD behavior.

Microsoft Defender for Office 365 (MDO)

What it is: Threat protection for email and collaboration workloads.

Use when: The scenario involves phishing, business email compromise, impersonation, malicious links, malicious attachments, or investigation of email-borne attacks.

Key capabilities: Safe Links, Safe Attachments, anti-phishing, investigation, automated response, attack simulation capabilities depending on licensing.

Exam cue: Safe Links = malicious URLs; Safe Attachments = malicious files; phishing/impersonation = Defender for Office 365.

Do not confuse: Purview DLP protects sensitive information; MDO protects against email/collaboration threats.

Microsoft Defender for Cloud Apps (MDCA)

What it is: Cloud Access Security Broker (CASB) and SaaS security/governance platform.

Use when: You need Shadow IT discovery, SaaS risk assessment, control of cloud-app usage, session controls, or visibility into unsanctioned cloud/AI applications.

Exam cue: "Discover which cloud apps employees are using" -> Defender for Cloud Apps.

Do not confuse: Defender for Cloud protects cloud infrastructure/workloads; Defender for Cloud Apps governs SaaS usage.

Microsoft Defender XDR

What it is: Extended Detection and Response that correlates Microsoft security signals and incidents across endpoints, identities, email, applications, and connected cloud signals.

Use when: A single attack spans multiple Microsoft security domains and the SOC needs one incident, investigation, advanced hunting, and coordinated response.

Exam cue: Phishing -> compromised identity -> compromised endpoint as one investigation -> Defender XDR.

Do not confuse: Sentinel is SIEM/SOAR for broader enterprise telemetry, including third-party data.

Microsoft Sentinel

What it is: Cloud-native SIEM and SOAR for centralized security analytics, detection, hunting, incident management, and automation.

Use when: The SOC needs logs from Azure, AWS, GCP, Microsoft security, firewalls, Linux/Windows, SaaS, and third-party tools; or needs KQL hunting and automated response playbooks.

Key capabilities: Data connectors, analytics rules, incidents, hunting, automation rules, playbooks/Logic Apps.

Exam cue: Third-party logs, enterprise SIEM, long-term analytics, KQL, or SOAR -> Sentinel.

Do not confuse: Defender XDR correlates Microsoft security-domain incidents. In modern SecOps, Sentinel and Defender XDR are integrated in the Defender portal.

Sentinel vs Defender XDR

Requirement	Best fit
Microsoft endpoint + email + identity correlation	Defender XDR
Enterprise SIEM across Microsoft and non-Microsoft sources	Microsoft Sentinel
SOAR automation across broad telemetry	Microsoft Sentinel
Microsoft-native cross-product incident investigation	Defender XDR
KQL threat hunting across SIEM data	Microsoft Sentinel
Unified modern SOC architecture	Use Sentinel + Defender XDR together in the Defender portal

MITRE ATT&CK and detection coverage

SC-100 expects architects to evaluate threat-detection coverage against MITRE ATT&CK, including Enterprise, Mobile, and Industrial Control Systems (ICS). The exam cue is not a Microsoft service name; it is the framework used to map tactics/techniques and find detection gaps.

2. Cloud Posture, Exposure & Hybrid/Multicloud Security

This chapter separates CSPM, workload protection, exposure management, outside-in discovery, hybrid control plane, and delegated tenant management.

Microsoft Defender for Cloud

What it is: Microsoft cloud-native application protection platform (CNAPP) for security posture management and cloud workload protection across Azure and supported multicloud environments.

Use when: You need cloud security recommendations, regulatory posture, MCSB alignment, attack-path context, workload protection, DevOps security, multicloud posture, or cloud entitlement analysis.

Key capabilities: Defender CSPM, secure score/recommendations, workload protection plans, multicloud connectors, regulatory compliance, DevOps and AI security capabilities.

Exam cue: "Are my Azure/AWS/GCP resources configured securely?" -> Defender for Cloud.

Do not confuse: Defender XDR is cross-domain incident detection/response; Defender for Cloud is cloud posture and workload security.

Defender for Cloud workload protection - choose by workload

Workload	Plan / capability	Typical scenario
VMs / servers	Defender for Servers	Protect Azure, Arc-enabled, and supported multicloud servers
Containers / Kubernetes	Defender for Containers	AKS/EKS/GKE/Kubernetes posture and runtime threat protection
Storage	Defender for Storage	Malware/suspicious storage activity and storage threats
SQL and databases	Defender for Databases	Database threat detection and vulnerability context
App Service	Defender for App Service	Threat protection for Azure App Service workloads
Key Vault	Defender for Key Vault	Detect suspicious Key Vault access/operations
Resource Manager	Defender for Resource Manager	Detect suspicious Azure resource-management operations
DevOps	Defender for DevOps / Defender for Cloud DevOps security	Repository/pipeline/IaC security posture and code-to-cloud context
APIs / AI services	Defender for Cloud capabilities/plans as applicable	API security posture and emerging AI workload protection scenarios

Defender for Cloud Permissions Management (CIEM)

What it is: Cloud Infrastructure Entitlement Management capabilities in Defender CSPM that analyze identities, effective permissions, unused/excessive access, and entitlement risk across supported Azure/AWS/GCP environments.

Use when: The requirement is to discover overprivileged identities, inactive permissions, excessive cloud entitlements, or paths created by permissions.

Exam cue: "Cloud infrastructure entitlement management" in the current blueprint -> think Defender for Cloud Permissions Management/CIEM.

Do not confuse: Do not rely on older study notes that point only to the retired standalone Entra Permissions Management product.

Microsoft Security Exposure Management

What it is: Cross-workload exposure management that uses an enterprise exposure graph, critical assets, attack paths, choke points, blast radius, insights, and initiatives to prioritize risk.

Use when: You need to understand how an attacker can move from an entry point through identities/endpoints/cloud resources to business-critical assets, and prioritize remediation based on attack paths.

Exam cue: "Attack path", "choke point", "critical asset", "blast radius", or cross-workload exposure -> Security Exposure Management.

Do not confuse: Defender for Cloud has cloud-focused attack-path capabilities; Security Exposure Management provides broader cross-workload exposure views.

Microsoft Defender External Attack Surface Management (Defender EASM)

What it is: Continuous outside-in discovery and mapping of an organization's externally visible digital attack surface.

Use when: You need to find unknown, forgotten, unmanaged, or Internet-exposed assets the organization may not know it owns.

Exam cue: "See the organization like an external attacker" -> Defender EASM.

Do not confuse: CSPM starts from connected/known cloud environments; EASM discovers the external attack surface from the Internet perspective.

Azure Arc

What it is: Azure control-plane extension for servers, Kubernetes, and other resources running outside Azure.

Use when: You need Azure management, policy, tagging, monitoring, Defender, or governance for on-premises, AWS, GCP, VMware, or other non-Azure resources.

Exam cue: Resource is not natively in Azure but should be managed from Azure -> Arc.

Do not confuse: Azure Lighthouse is cross-tenant delegation; Arc is hybrid/multicloud resource onboarding and management.

Azure Lighthouse

What it is: Delegated resource management across Microsoft Entra tenants for Azure resources, commonly used by service providers/MSSPs.

Use when: A provider or central team must manage Azure resources in customer/subsidiary tenants without traditional tenant switching or permanent local administration.

Exam cue: "MSSP manages customer Azure resources" or delegated cross-tenant Azure management -> Lighthouse.

Do not confuse: For modern multi-tenant Defender XDR/Sentinel investigations, also know the Microsoft Defender portal multitenant-management capabilities. Lighthouse remains an Azure delegated-resource-management construct.

Arc vs Lighthouse - memory rule

Memory hook: Arc = WHERE the resource runs. Lighthouse = WHO/WHICH tenant manages Azure resources.

Scenario	Use
On-premises Windows/Linux server managed as an Azure resource	Azure Arc
AWS/GCP Kubernetes attached to Azure control plane	Azure Arc-enabled Kubernetes
MSSP manages customer Azure subscription resources	Azure Lighthouse
MSSP manages customer on-prem servers through Azure	Azure Arc + Azure Lighthouse can be combined

3. Identity, Authentication & Privileged Access

Most identity questions become easy if you separate authentication, risk, authorization, privilege activation, and access lifecycle.

Microsoft Entra ID

What it is: Cloud identity and access management for users, groups, applications, workload identities, authentication, authorization, and federation/hybrid identity.

Use when: The architecture centers on user/application identity, SSO, authentication, external identity, hybrid identity, or access to SaaS/PaaS/IaaS resources.

Exam cue: Identity plane -> Entra ID; then choose the specific control such as Conditional Access, PIM, ID Protection, or managed identities.

Conditional Access

What it is: Policy engine that evaluates identity/device/location/risk/app context and applies access controls such as MFA, authentication strength, device requirements, block, or session controls.

Use when: The scenario has an IF/THEN access decision: risky sign-in, admin access, unmanaged device, untrusted location, sensitive app, compliant device requirement.

Exam cue: If condition -> then require/block/control access = Conditional Access.

Do not confuse: PIM controls role activation; Conditional Access controls access based on conditions.

Continuous Access Evaluation (CAE)

What it is: Near-real-time access reevaluation for supported critical events and policy changes rather than relying only on token expiration.

Use when: The requirement is to react quickly when an account is disabled, user risk changes, or access conditions change during an existing session.

Exam cue: "Reevaluate access without waiting for token expiry" -> CAE.

Microsoft Entra ID Protection

What it is: Identity risk detection that produces user-risk and sign-in-risk signals for investigation and policy decisions.

Use when: You need risk-based access controls for leaked credentials, suspicious sign-ins, or potentially compromised users.

Exam cue: Risky user/sign-in -> ID Protection + Conditional Access.

Do not confuse: Defender for Identity focuses on identity attacks/AD signals, not merely sign-in risk.

Microsoft Entra Privileged Identity Management (PIM)

What it is: Just-in-time and governed privileged-role activation for Entra and supported Azure roles.

Use when: Administrators should be eligible rather than permanently active, with time limits, approval, MFA, justification, notifications, and access reviews.

Exam cue: "Temporary Global Administrator for two hours" -> PIM.

Do not confuse: Entitlement Management gives resource access packages; PIM gives governed privileged-role activation.

Entitlement Management

What it is: Identity Governance capability for access packages, request/approval workflows, external-user access, expiration, and lifecycle.

Use when: Contractors/partners/project users need a bundle of groups, Teams/SharePoint/apps with approval and automatic expiry.

Exam cue: "Access package" or temporary project bundle -> Entitlement Management.

Access Reviews

What it is: Periodic recertification of group membership, application access, privileged roles, and other assignments.

Use when: The requirement is to periodically verify whether users/guests/admins still need access and remove stale access.

Exam cue: "Does the person still need this access?" -> Access Review.

Microsoft Entra External ID / B2B

What it is: External identity collaboration for partners, suppliers, guests, and customer/external scenarios.

Use when: The organization wants external users to use their own identities while accessing shared resources under organizational policy.

Exam cue: Partner collaboration without creating ordinary employee identities -> External ID/B2B.

Microsoft Entra Agent ID

What it is: Identity, governance, permissions, lifecycle, and policy controls for AI agents.

Use when: An autonomous or semi-autonomous AI agent needs a distinct enterprise identity, attributable actions, permissions, Conditional Access, risk controls, and lifecycle governance.

Exam cue: AI agent identity -> Entra Agent ID.

Do not confuse: Managed identity/workload identity is for workload-to-resource access; Agent ID specifically addresses governed agent identities.

Managed Identities for Azure Resources

What it is: Microsoft-managed workload identities that allow Azure workloads to authenticate to supported resources without embedding credentials.

Use when: A VM, Function, App Service, Automation account, or other Azure workload needs to access Key Vault, Storage, SQL, or another resource without storing secrets.

Exam cue: "No credentials in code/config" -> Managed Identity + RBAC.

Do not confuse: Key Vault stores secrets; managed identity can eliminate the need to store an application credential at all.

PIM vs Entitlement Management vs Access Review

Question	Choose
Need temporary privileged admin role?	PIM
Need a package of project resources with request/approval/expiry?	Entitlement Management
Need periodic proof that existing access is still required?	Access Reviews

Entra roles vs Azure RBAC

What is being administered?	Authorization model
Entra users, groups, identity governance, Conditional Access	Microsoft Entra roles
Azure VMs, networks, storage accounts, resource groups, subscriptions	Azure RBAC

Secure privileged administration

- Use least privilege and separate admin identities.
- Use PIM to reduce standing privilege.
- Protect admin sign-in with phishing-resistant MFA/authentication strength where appropriate.
- Use secure/privileged access workstations for high-impact administration.
- Review privileged access regularly and maintain emergency/break-glass access procedures.
- Harden AD DS and tier administrative access to reduce credential theft and lateral movement.

4. Governance, Policy, Secure Score & Compliance

Differentiate authorization, configuration governance, posture measurement, regulatory evidence, and data compliance.

Azure RBAC

What it is: Role-based authorization for Azure resources at management group, subscription, resource group, or resource scope.

Use when: The question is "who can perform which Azure management/data action at what scope?"

Exam cue: RBAC = WHO can do WHAT at WHICH Azure scope.

Do not confuse: Azure Policy controls resource configuration; RBAC controls permissions.

Azure Policy

What it is: Governance engine that evaluates and enforces standards for Azure resources and reports compliance.

Use when: You need to deny noncompliant deployments, audit configurations, modify settings/tags, or deploy required configuration at scale.

Exam cue: "All storage accounts must disable public access" -> Azure Policy.

Do not confuse: RBAC says whether a user may create a resource; Policy says what configurations are permitted.

Azure Policy effects - exam-level recognition

Effect	Use
Audit	Flag noncompliant resources without blocking deployment
Deny	Prevent noncompliant creation/update
Modify	Add/change supported resource properties or tags
DeployIfNotExists	Deploy related configuration/resources when a condition is missing

Policy initiative = a group of policy definitions treated as one compliance objective, useful for security baselines or regulatory frameworks.

Microsoft Secure Score

What it is: A posture metric that prioritizes recommended security improvements and helps track progress.

Use when: Management or security teams need a measurable posture score, prioritized recommendations, or trend/improvement metric.

Exam cue: "Measure/improve posture" -> Secure Score; "enforce configuration" -> Azure Policy.

Microsoft Purview

What it is: Microsoft data security, governance, risk, and compliance family covering information protection, DLP, audit, insider risk, eDiscovery, records/compliance capabilities, and data governance.

Use when: The scenario focuses on sensitive data, compliance, audit, retention, insider risk, classification, or data-governance controls.

Exam cue: Data/compliance problem -> consider Purview before Defender.

Do not confuse: Defender primarily addresses threats; Purview primarily addresses data security/governance/compliance. Some scenarios require both.

Microsoft Purview Audit

What it is: Unified audit logging and investigation of user/admin actions across Microsoft 365 and supported services.

Use when: You need to determine who performed an administrative or user action, support forensic investigation, or centralize M365 audit evidence.

Exam cue: "Who did what and when in Microsoft 365?" -> Purview Audit.

Compliance architecture

- Translate regulatory requirements into technical and procedural controls.
- Use Purview for data/compliance controls and evidence in Microsoft 365/data scenarios.
- Use Azure Policy/initiatives for Azure configuration and compliance governance.
- Use Defender for Cloud regulatory-compliance dashboards/recommendations to validate cloud posture against standards and benchmarks.

5. Microsoft 365, Information Protection & Data Loss

Security question: threat, device, or data? That determines whether Defender, Intune, or Purview is the center of the answer.

Microsoft Purview Information Protection

What it is: Discover, classify, label, and protect sensitive information using sensitivity labels, sensitive information types, and related controls.

Use when: You need to identify credit card/PII/confidential documents, label them, apply encryption/markings, or create a classification taxonomy.

Exam cue: Classification/labeling -> Information Protection.

Do not confuse: DLP enforces what users can do with the data after identification/classification.

Microsoft Purview Data Loss Prevention (DLP)

What it is: Policy controls that detect sensitive information and prevent or govern inappropriate sharing/exfiltration across supported Microsoft 365 endpoints and services.

Use when: A user tries to email, upload, copy, or share sensitive data in a prohibited way.

Exam cue: "Prevent sensitive data from leaving" -> DLP.

Microsoft Purview Insider Risk Management

What it is: Risk management for potentially malicious or inadvertent internal behavior involving sensitive data and policy violations.

Use when: You need to investigate unusual employee data downloads, IP theft indicators, risky departures, or insider exfiltration patterns.

Exam cue: "Insider behavior" -> Insider Risk Management.

Do not confuse: DLP blocks/controls data actions; Insider Risk correlates behavior and signals for investigation.

Microsoft Intune

What it is: Endpoint management for device enrollment, configuration, security baselines, compliance, mobile device management (MDM), and mobile application management (MAM).

Use when: You need to configure devices, enforce compliance, deploy security settings, manage corporate/mobile endpoints, or feed device compliance into Conditional Access.

Exam cue: Manage/configure/compliance -> Intune; detect/respond to endpoint attack -> MDE.

Defender vs Purview vs Intune - fast triage

Question is about...	Choose
Phishing/malware/threat attack	Microsoft Defender products
Sensitive data, classification, compliance, insider risk	Microsoft Purview
Device configuration, MDM/MAM, compliance state	Microsoft Intune
Access decision using device/risk context	Conditional Access, fed by Intune/Defender signals

Microsoft 365 Copilot - security architecture cue

Current SC-100 explicitly includes data security and compliance controls for Microsoft 365 Copilot. Architecturally, focus on identity/Conditional Access, least privilege, Purview classification/DLP/compliance, appropriate sharing permissions, audit, and reducing overshared data before enabling broad Copilot usage.

6. Endpoints, Servers, IoT/OT & Security Baselines

Know the management plane, threat-detection plane, local-admin credential control, and specialized OT protection.

Windows LAPS

What it is: Local Administrator Password Solution that manages unique, rotating local administrator passwords for Windows devices.

Use when: The organization wants to eliminate shared/reused local administrator passwords and rotate them automatically.

Exam cue: "Unique rotating local admin password per Windows device" -> Windows LAPS.

Microsoft Defender for IoT

What it is: Specialized visibility, asset discovery, vulnerability/risk monitoring, and threat detection for operational technology (OT), ICS, and IoT environments.

Use when: The assets are PLCs, SCADA systems, industrial controllers, manufacturing/medical OT, or devices that cannot run normal endpoint agents.

Exam cue: PLC/SCADA/ICS -> Defender for IoT.

Do not confuse: Laptop/server threat protection -> Defender for Endpoint.

Endpoint/security baseline architecture

- Harden server/client configuration using security baselines and policy.
- Use Intune for device configuration/compliance and MDE for endpoint threat detection/response.
- Use Windows LAPS to reduce local-admin credential reuse.
- Use Defender for Servers / Arc for hybrid server protection and posture as appropriate.
- For OT/ICS, prioritize passive/specialized monitoring and segmentation; do not assume ordinary endpoint agents are suitable.

7. Network Security & Security Service Edge (SSE)

Identify which layer is being protected: subnet packet filtering, centralized firewalling, HTTP application attacks, DDoS, private PaaS, admin access, or identity-aware SSE.

Layered network mental model

Think in layers: Internet -> DDoS protection -> WAF for HTTP/S -> Azure Firewall for centralized network control -> NSG for subnet/NIC filtering -> workload. Add Private Link/Endpoint when PaaS should be privately addressed.

Network Security Group (NSG)

What it is: Stateful L3/L4 network filtering on Azure subnets and network interfaces.

Use when: You need allow/deny rules based on source/destination, port, protocol, and direction close to a subnet/NIC.

Exam cue: Basic subnet/NIC packet filtering -> NSG.

Do not confuse: Azure Firewall provides centralized, richer firewall capabilities.

Application Security Group (ASG)

What it is: Logical grouping of VM network interfaces used as sources/destinations in NSG rules.

Use when: You want NSG rules to follow application roles such as WebServers/AppServers rather than maintaining IP lists.

Exam cue: Logical VM grouping inside NSG rules -> ASG.

Azure Firewall

What it is: Managed, centralized, stateful Azure network firewall with network/application rules and advanced capabilities depending on tier.

Use when: You need centralized egress/ingress filtering, FQDN/application rules, threat intelligence, hub-and-spoke control, or advanced inspection/IDPS/TLS inspection where supported.

Exam cue: Central intelligent firewall across VNets -> Azure Firewall.

Do not confuse: WAF protects HTTP application attacks; Azure Firewall is the broader network firewall.

Azure Web Application Firewall (WAF)

What it is: Layer 7 web-application firewall for HTTP/S threats such as SQL injection, cross-site scripting, and common OWASP attack patterns.

Use when: A public web application/API needs protection from application-layer attacks through Application Gateway/Front Door WAF architectures.

Exam cue: SQL injection or XSS -> WAF.

Do not confuse: DDoS Protection addresses network-layer volumetric attacks; Azure Firewall is a network firewall.

Azure DDoS Protection

What it is: Managed protection against network-layer distributed denial-of-service attacks targeting Azure resources with public IP exposure.

Use when: You need mitigation against volumetric or protocol attacks at L3/L4.

Exam cue: UDP flood / volumetric L3-L4 attack -> DDoS Protection; HTTP exploit -> WAF.

Azure Bastion

What it is: Managed RDP/SSH access to Azure VMs using private IP connectivity without exposing RDP/SSH directly on VM public IPs.

Use when: Administrators require RDP/SSH access but VMs should not have management ports exposed to the Internet.

Exam cue: Secure RDP/SSH without VM public IP -> Bastion.

Private Endpoint / Azure Private Link

What it is: Private connectivity that gives a supported Azure PaaS resource a private IP address in your virtual network.

Use when: SQL, Storage, Key Vault, or another supported PaaS service should be accessed privately from VNet/on-prem connected networks and public exposure should be minimized.

Exam cue: "Private IP for PaaS" -> Private Endpoint.

Do not confuse: Service endpoints secure access to the service over Azure networking but the service retains a publicly routable endpoint; Private Endpoint puts a private IP in your VNet.

Service Endpoint vs Private Endpoint

Characteristic	Service Endpoint	Private Endpoint
Destination addressing	Service public endpoint	Private IP in your VNet
Private IP for service in VNet	No	Yes
Strong granular private PaaS pattern	Limited compared with Private Link	Yes
Common exam preference when requirement says "private IP"	No	Yes

Microsoft Entra Internet Access

What it is: Identity-aware Secure Web Gateway (SWG) in Microsoft's Security Service Edge (SSE) solution for Internet and SaaS traffic.

Use when: You need secure Internet/SaaS access, web-content filtering, identity/device/risk context, or Conditional Access applied to Internet destinations.

Exam cue: Public Internet/SaaS traffic -> Entra Internet Access.

Do not confuse: Entra Private Access is ZTNA for private/internal resources.

Microsoft Entra Private Access

What it is: Zero Trust Network Access (ZTNA) for granular private application/resources access using identity and Conditional Access rather than broad network VPN access.

Use when: Remote/office users should access specific private apps, FQDNs, IPs, ports, or protocols without receiving broad corporate network access.

Exam cue: Private/internal application or VPN replacement -> Entra Private Access.

Do not confuse: Internet/SaaS browsing -> Entra Internet Access.

Internet Access vs Private Access

Destination / requirement	Choose
Internet websites and SaaS	Entra Internet Access
Microsoft service traffic with Entra Internet Access for Microsoft Services	Entra Internet Access for Microsoft Services
On-prem/internal/private application	Entra Private Access
Per-app ZTNA instead of broad VPN	Entra Private Access

8. Application Security, APIs, DevSecOps & Workload Identity

Architect the full lifecycle: threat model -> secure development -> identity -> secrets -> network -> runtime protection -> monitoring.

Azure Key Vault

What it is: Managed service for secrets, cryptographic keys, and certificates.

Use when: Applications need protected storage/lifecycle for passwords, keys, certificates, or customer-managed encryption keys.

Exam cue: Secrets/keys/certificates -> Key Vault.

Do not confuse: If a workload can use managed identity instead of an application secret, prefer eliminating the stored credential.

Azure API Management (APIM)

What it is: API gateway and management platform for publishing, securing, transforming, throttling, monitoring, and governing APIs.

Use when: You need centralized API authentication/authorization policies, JWT validation, rate limiting, quotas, transformations, versioning, or developer-facing API governance.

Exam cue: "Secure/govern APIs" -> API Management.

Do not confuse: WAF protects HTTP attack patterns at the web perimeter; APIM governs API access and policy behavior.

Threat modeling

Current SC-100 expects evaluation of threats to business-critical applications using threat modeling. The architectural goal is to identify assets, trust boundaries, data flows, threats, mitigations, and residual risk before choosing controls.

DevSecOps - security across the lifecycle

Lifecycle stage	Security focus
Design	Threat modeling, secure architecture, identity and trust boundaries
Code	Secret scanning, static analysis, secure coding, dependency management
Build	Dependency/container/IaC scanning, signed artifacts, pipeline hardening
Deploy	Policy-as-code, least privilege, environment separation, approvals
Run	Defender runtime protection, logging, Sentinel/XDR, vulnerability management

Typical secure Azure application pattern

Reference flow: Internet -> DDoS -> Front Door/Application Gateway + WAF -> application -> managed identity -> Private Endpoint -> data service; Key Vault for keys/certs; Defender for Cloud for posture/workload security; Sentinel/XDR for monitoring.

Containers and Kubernetes

- Azure-native Kubernetes: AKS plus Entra/RBAC, network controls, Azure Policy, Defender for Containers, secure images, and secrets management.
- Kubernetes outside Azure: connect with Azure Arc-enabled Kubernetes when Azure governance/Defender/Policy control is required.
- Container security includes image/supply-chain risk, orchestration configuration, runtime detection, network segmentation, identity, and least privilege.

Azure AI services and agentic AI security

- Treat AI services as workloads with identity, network, data, logging, and supply-chain controls.
- Use Entra Agent ID for governed AI-agent identities where applicable.
- Protect prompts, grounding data, model outputs, secrets, and connectors using Purview, encryption, Key Vault, RBAC, and private networking as appropriate.
- Use Defender for Cloud capabilities to assess and protect cloud/AI workloads as supported; align AI controls with MCSB and Zero Trust.

9. Data Security, Encryption, Storage & Databases

Start by asking where the data is, how sensitive it is, and whether the problem is confidentiality, access, exfiltration, or workload threat detection.

Three states of data

State	Primary controls
Data at rest	Service encryption, customer-managed keys where required, Key Vault, access control, backups
Data in transit	TLS, private connectivity, certificate management, network controls
Data in use	Least privilege, identity, application controls, confidential-computing options where requirements justify them

Azure Storage

- Use Entra ID/RBAC where possible for authorization rather than long-lived shared keys.
- Use Private Endpoint when private IP connectivity is required.
- Use encryption at rest; use customer-managed keys when the compliance/control requirement demands customer key ownership.
- Use Defender for Storage for storage workload threat detection and malware/suspicious activity scenarios.
- Use immutability/versioning/backup patterns where ransomware resilience and recovery integrity require them.

Azure SQL / Synapse / Cosmos DB

- Prefer identity-based authentication and least-privilege authorization.
- Use private networking when public exposure is not required.
- Apply encryption at rest and in transit, and customer-managed keys when required.
- Use Defender for Databases for threat detection and database security signals where supported.

Key Vault + managed identity pattern

Preferred pattern: Application authenticates with managed identity -> Azure RBAC grants only required permissions -> Key Vault stores keys/certificates/secrets that truly must exist. Avoid hard-coded credentials.

Data used in AI workloads

Current SC-100 explicitly includes security for data used by AI. Apply the same data-security disciplines: discover/classify sensitive data, minimize and govern access, protect vector stores/grounding data, encrypt data, prevent inappropriate disclosure with Purview controls, secure connectors and workload identities, and monitor AI workload access and activity.

10. Frameworks, Landing Zones, Zero Trust & Ransomware Resiliency

SC-100 expects you to choose architectures that align with Microsoft security frameworks, not just individual products.

Framework map

Framework / concept	What it answers
Zero Trust	How should every access decision be made? Verify explicitly, use least privilege, assume breach.
MCSB - Microsoft Cloud Security Benchmark	What cloud security controls/baselines should exist across major security domains?
MCRA - Microsoft Cybersecurity Reference Architectures	How Microsoft security capabilities and architectural patterns fit together.
CAF - Cloud Adoption Framework	How the organization should plan, govern, secure, manage, and adopt cloud at scale.
Azure Well-Architected Framework	How a workload should balance reliability, security, cost optimization, operational excellence, and performance efficiency.
Azure Landing Zones	Enterprise Azure foundation: management groups, subscriptions, identity, networking, policy, governance, shared platform services.

Zero Trust by domain

Domain	Typical controls
Identity	MFA/authentication strength, Conditional Access, ID Protection, PIM, least privilege
Devices	Intune compliance, MDE, security baselines
Applications	Strong auth, managed identities, APIM, WAF, secure SDLC
Network	Segmentation, Firewall/NSG, Private Link, ZTNA/SSE, DDoS/WAF
Data	Classification, Purview, DLP, encryption, Key Vault
Infrastructure	Defender for Cloud, Azure Policy, Arc, secure configuration

Azure Landing Zones - when to choose

Choose Azure Landing Zones when an enterprise needs repeatable, scalable, secure subscription foundations rather than one-off workload architecture. Landing zones standardize management-group hierarchy, subscription vending, policy, RBAC, network topology, platform services, security monitoring, and governance.

Ransomware resiliency architecture

Phase	Architectural controls
Prevent	Zero Trust, MFA, PIM, secure admin workstations, patching, hardening, MDE, segmentation
Detect	Defender products, Defender XDR, Sentinel, exposure/attack-path visibility
Contain	Identity/session revocation, endpoint isolation, segmentation, incident-response workflows
Recover	Secure backups, immutable/protected recovery points, tested restore, BCDR and business-priority recovery sequencing

Exam trap: Backups alone are not a ransomware strategy. Microsoft architecture emphasizes identity/privileged-access protection, detection/containment, and secure tested recovery.

Azure Backup and Azure Site Recovery - quick distinction

Need	Think
Recover deleted/corrupted/encrypted data from protected restore points	Azure Backup and secure backup design
Replicate workloads and fail over to another location for business continuity	Azure Site Recovery / BCDR design

11. Scenario Drills - Answer in One Line

Use these to train the first service/control that should come to mind.

Scenario	Best first answer
Employees use unknown generative-AI websites and security wants discovery/risk scoring.	Defender for Cloud Apps - Shadow IT/SaaS discovery.
SOC ingests Palo Alto, Linux, AWS, Azure, and Defender alerts and needs KQL hunting.	Microsoft Sentinel - SIEM.
One phishing campaign leads to identity compromise and endpoint malware and must be investigated as one incident.	Microsoft Defender XDR.
Administrators should only be Global Admin for approved 1-hour windows.	Microsoft Entra PIM.
Medium/high sign-in risk should trigger MFA or block.	ID Protection risk + Conditional Access.
A contractor needs Teams, SharePoint, and an app for 60 days with manager approval.	Entitlement Management access package.
Every quarter, guest access must be recertified.	Access Reviews.
An AI agent must have a distinct governed identity and Conditional Access policy.	Microsoft Entra Agent ID.
A Function needs to read Key Vault without storing a client secret.	Managed Identity + RBAC.
All Azure Storage accounts must block public network access.	Azure Policy.
A developer may manage VMs only in one resource group.	Azure RBAC scoped to the resource group.
Security wants to find forgotten Internet-exposed domains/IPs that belong to the company.	Defender EASM.
Security wants to see routes from an exposed VM through identities to a critical domain controller.	Security Exposure Management attack paths.
A non-Azure Kubernetes cluster must be governed with Azure Policy and Defender.	Azure Arc-enabled Kubernetes.
An MSSP needs delegated management of customer Azure resources.	Azure Lighthouse.
Cloud team must identify excessive and unused permissions in Azure/AWS/GCP.	Defender for Cloud Permissions Management (CIEM).
A manufacturing plant has PLCs and SCADA devices that cannot run endpoint agents.	Microsoft Defender for IoT.
Security must centrally filter outbound Internet traffic by FQDN across hub-spoke VNETs.	Azure Firewall.
Only HTTPS should reach a web subnet; SSH must be denied.	NSG.
Public app must be protected against SQL injection/XSS.	WAF.
Public IPs need mitigation against volumetric L3/L4 attacks.	Azure DDoS Protection.
Admins need RDP to VMs with no VM public IPs.	Azure Bastion.
Azure SQL must have a private IP reachable from the VNET/on-prem network.	Private Endpoint / Private Link.
Remote users need only one internal app without broad VPN access.	Microsoft Entra Private Access.
Security wants identity-aware filtering for Internet/SaaS browsing.	Microsoft Entra Internet Access.
A document containing card numbers must be automatically identified and labeled.	Purview Information Protection.
Users must be blocked from emailing sensitive card data externally.	Purview DLP.
Employee downloads thousands of confidential files before resignation.	Purview Insider Risk Management.
Auditor asks who deleted a SharePoint item and when.	Purview Audit.

Scenario	Best first answer
Company wants a numerical posture metric and prioritized improvements.	Microsoft Secure Score.
Ransomware recovery requires protected restore points and tested restoration.	Secure Azure Backup/BCDR architecture; combine with identity and endpoint protections.

12. High-Value Exam Traps & Similar-Service Comparisons

If two choices look plausible, use the distinction in the right column.

Looks similar	Decision rule
Sentinel vs Defender XDR	Sentinel = enterprise SIEM/SOAR across broad sources. Defender XDR = Microsoft cross-domain XDR incident correlation.
Defender for Cloud vs Defender for Cloud Apps	Defender for Cloud = cloud infrastructure/workloads/CNAPP. Defender for Cloud Apps = SaaS/CASB/Shadow IT.
Defender for Identity vs Entra ID Protection	MDI = identity attacks/hybrid AD behavior. ID Protection = risky user/sign-in signals.
Intune vs Defender for Endpoint	Intune = manage/configure/compliance. MDE = endpoint detect/investigate/respond.
Arc vs Lighthouse	Arc = hybrid/multicloud resources. Lighthouse = delegated cross-tenant Azure resource management.
EASM vs Security Exposure Management	EASM = discover external Internet-facing attack surface. Exposure Management = prioritize risk/attack paths across workloads and critical assets.
Defender CSPM vs Secure Score	CSPM = cloud posture engine/recommendations. Secure Score = posture metric/prioritized improvement score.
PIM vs Conditional Access	PIM = activate privilege. Conditional Access = decide access under conditions.
PIM vs Entitlement Management	PIM = privileged roles. Entitlement = resource access packages/lifecycle.
Entitlement Management vs Access Reviews	Entitlement grants/governs lifecycle; Access Reviews recertify existing access.
RBAC vs Azure Policy	RBAC = who can perform actions. Policy = what resource configurations are allowed/required.
Azure Firewall vs WAF	Firewall = centralized network filtering. WAF = HTTP/S web-application attack protection.
DDoS vs WAF	DDoS = L3/L4 volumetric/protocol attacks. WAF = L7 HTTP attacks.
NSG vs Azure Firewall	NSG = distributed subnet/NIC packet rules. Firewall = centralized richer network/application inspection.
Service Endpoint vs Private Endpoint	Service endpoint still targets service public endpoint; Private Endpoint gives the service a private IP in your VNet.
Entra Internet Access vs Private Access	Internet Access = Internet/SaaS SWG. Private Access = private-app ZTNA.
Key Vault vs Managed Identity	Key Vault stores secrets/keys/certs. Managed identity lets workloads authenticate without storing credentials.
Defender vs Purview	Defender = attacks/threats. Purview = data security/governance/compliance.
Backup vs Site Recovery	Backup = restore data/restore points. Site Recovery = replication/failover for BCDR.
Cloud CIEM older notes	Current exam cue: Defender for Cloud Permissions Management/CIEM rather than treating old standalone Entra Permissions Management as the answer.

13. Final-Day Rapid Revision Sheet

Read this page the night before the exam and again before entering the test center.

Service / capability	One-line memory hook
MDE	Endpoint EDR / endpoint threats
MDI	AD / identity attacks
MDO	Email phishing / links / attachments
MDCA	SaaS / CASB / Shadow IT

Service / capability	One-line memory hook
Defender XDR	Microsoft cross-domain incidents
Sentinel	SIEM + SOAR + KQL + third-party logs
Defender for Cloud	CNAPP: CSPM + workload protection
Defender CSPM CIEM	Excessive/unused cloud entitlements
EASM	Outside-in Internet attack surface
Exposure Management	Cross-workload attack paths / critical assets
Arc	Hybrid/multicloud resource management
Lighthouse	Cross-tenant Azure delegation
Conditional Access	IF condition -> THEN access control
ID Protection	User/sign-in risk
PIM	JIT privileged role
Entitlement Management	Access packages
Access Reviews	Does access still belong?
Agent ID	AI agent identity
Managed Identity	Credential-free Azure workload identity
Intune	Manage/configure/compliance
LAPS	Unique rotating local admin password
Defender for IoT	OT/ICS/SCADA/PLC
Azure RBAC	WHO can do WHAT at scope
Azure Policy	WHAT resource configuration is allowed
Secure Score	HOW strong is posture
Purview Info Protection	Classify/label data
Purview DLP	Stop inappropriate sensitive-data movement
Insider Risk	Insider behavior
Purview Audit	Who did what
NSG	Subnet/NIC packet filter
ASG	Logical VM grouping for NSG
Azure Firewall	Central network firewall
WAF	Web attacks / SQLi / XSS
DDoS Protection	L3/L4 DDoS
Bastion	RDP/SSH without VM public IP
Private Endpoint	Private IP for PaaS
Entra Internet Access	Internet/SaaS secure web gateway
Entra Private Access	Private app ZTNA / VPN replacement
Key Vault	Secrets/keys/certs
API Management	API gateway/policies
Defender for Storage	Storage threats
Defender for Databases	Database threats
Defender for Containers	Kubernetes/container security

Final exam method: 1) Identify the protected asset. 2) Identify control objective: prevent, detect, govern, authorize, recover. 3) Eliminate services at the wrong layer. 4) Prefer the service that directly satisfies the requirement with least unnecessary scope.

14. Official Microsoft References & Scope Notes

Use these pages to verify current product behavior and exam wording. Microsoft may update features after this guide is produced.

SC-100 Exam page - <https://learn.microsoft.com/en-us/credentials/certifications/exams/sc-100/>

SC-100 Study guide - skills measured - <https://learn.microsoft.com/en-us/credentials/certifications/resources/study-guides/sc-100>

Microsoft Defender for Cloud overview - <https://learn.microsoft.com/en-us/azure/defender-for-cloud/defender-for-cloud-introduction>

Defender for Cloud CIEM / Permissions Management - <https://learn.microsoft.com/en-us/azure/defender-for-cloud/permissions-management>

Microsoft Security Exposure Management - attack paths - <https://learn.microsoft.com/en-us/security-exposure-management/work-attack-paths-overview>

Defender External Attack Surface Management - <https://learn.microsoft.com/en-us/azure/external-attack-surface-management/>

Global Secure Access overview - <https://learn.microsoft.com/en-us/entra/global-secure-access/overview-what-is-global-secure-access>

Microsoft Entra Private Access - <https://learn.microsoft.com/en-us/entra/global-secure-access/concept-private-access>

Azure Arc-enabled Kubernetes - <https://learn.microsoft.com/en-us/azure/azure-arc/kubernetes/overview>

Azure Lighthouse with Microsoft Sentinel for MSSPs - <https://learn.microsoft.com/en-us/azure/sentinel/multiple-tenants-service-providers>

Scope note: This guide is intentionally scenario-oriented. It includes the services explicitly named in the July 28, 2026 SC-100 blueprint plus closely related Azure/Microsoft security controls that commonly appear in architecture scenarios. It is a study aid, not a replacement for Microsoft Learn and hands-on practice.

Version: 2026-08-09